

ATTACK TYPE	SEVERITY	CONFIDENCE	SUBTYPE
XSS	HIGH	99.2%	Script-tag XSS

[WARNING] A high-severity Cross-Site Scripting (XSS) payload classified as Script-tag XSS was detected in a POST request to /api/xai/report originating from IP address 127.0.0.1 using a WindowsPowerShell user agent. The payload <script>alert(1)</script> was identified with a model probability score of 0.992.

Payload

<script>alert(1)</script>

Request Metadata

Field	Value
ip	127.0.0.1
user_agent	Mozilla/5.0 (Windows NT; Windows NT 10.0; en-US) WindowsPowerShell/5.1.26100.8894
path	/api/xai/report
method	POST

Attack-Specific Explanation

- The payload contains a explicit script tag construct paired with an alert call JavaScript function.
- Pattern detection identified strong indicator script_tag along with weak indicators angle_brackets and alert_call.
- Top TF-IDF feature tokens including ript>, ipt>, pt>, and cript contributed heavily to the model classification.

Top TF-IDF Terms (Why It Was Flagged)

Token	TF-IDF Score	Visual
ript>	0.2419	#####
ipt>	0.2419	#####
pt>	0.2419	#####
ipt	0.2300	##### -
cript	0.2300	##### -
scrip	0.2300	##### -
crip	0.2300	##### -
ript	0.2300	##### -
scri	0.2281	##### - -
rip	0.2281	##### - -

Potential Impact & Recommended Protections

Potential Impact	Recommended Protections
- Execution of attacker-controlled JavaScript in the victim browser.	- Apply strict output encoding for HTML, attributes, URLs, and JavaScript contexts.
- Session theft, token theft, UI manipulation, or phishing-style redirection.	- Enable Content-Security-Policy (CSP) to reduce script execution risk.
	- Sanitize rich HTML input with a strict allow-list if HTML is required.

Attack Preconditions

1	User-controlled data is rendered in browser output without proper escaping.
2	The application allows executable HTML or script-like payloads to reach the response.

Decision Debug / AI Gating

Key	Value
raw_pred	2

Key	Value
proba	{ "0": 0.0022653367278158603, "1": 0.005595228301208669, "2": 0.992, "3": 0.00013943497097547076 }
pattern_hits	{ "sqli": { "strong": [], "weak": [] }, "xss": { "strong": ["script_tag"], "weak": ["angle_brackets", "alert_call"] }, "lfi": { "strong": [], "weak": [] } }
decision_reason	multi_allowed_choose_highest
thresholds	{ "sqli": { "no_pattern_min": 0.85, "weak_min": 0.8, "strong_min": 0.6 }, "xss": { "no_pattern_min": 0.85, "weak_min": 0.8, "strong_min": 0.6 }, "lfi": { "no_pattern_min": 0.85, "weak_min": 0.8, "strong_min": 0.6 } }

AI Analyst Note

- The request originated from a PowerShell client targeting /api/xai/report. While the payload represents a standard proof-of-concept alert attempt, actual exploitation is contingent upon whether the endpoint echoes or stores this input for presentation in a web browser context without sanitization.

Report Note

- This report was automatically generated by the HWACS Explainable AI Security Platform using captured request data, model prediction output, pattern-based analysis, subtype detection, and explainability signals. The result should be reviewed by a qualified security professional before taking operational action.